

Xolvon Backend — Handover Documentation

Official handover entry point for the Xolvon backend (NestJS 12, strict ESM, Node.js 22+). This folder is the canonical, code-verified reference. The root `README.md` and `ARCHITECTURE.md` predate some hardening work; where they disagree with this folder, the documents here (and the code) win.

Document index

Document	Purpose
<code>README.md</code> (this file)	From-zero setup, environment variables, commands, migrations, PDF build
<code>architecture.md</code>	Module map, data layer (SQLite/D1), storage port, auth model, full data model
<code>security.md</code>	Security headers, input sanitization, consolidated controls, audit results, limitations
<code>deployment-runbook.md</code>	Staging → production deployment, migration apply/rollback, admin bootstrap, monitoring status
<code>api-contract.md</code>	Canonical endpoint contract (auth/role per route)
<code>decision-log.md</code>	Locked decisions (DL- <i>nnn</i>), conflicts, open items
<code>production-operations.md</code>	Environment separation, admin bootstrap, rollback, observability boundary
<code>qa-results.md</code>	Live-deployment verification status (currently BLOCKED — recorded honestly)

1. Prerequisites

- **Node.js** v22.0.0+ (NestJS 12 runs native ESM)
- **npm** v10+
- No Cloudflare account, database, or bucket is needed for local development.

2. From-zero local setup

2.1 Clone and install

```
git clone <repository-url>
cd Project-SaaS-Xolvon
npm install
```

`.npmrc` sets `legacy-peer-deps=true` (required by the `@nestjs/throttler` peer range, see DL-016); a clean `npm install` on a fresh clone must exit 0.

2.2 Create `.env`

```
cp .env.example .env
```

`.env` is gitignored — never commit it. The local defaults in `.env.example` run fully offline: `APP_ENV=local`, `DB_DRIVER=sqlite`, `STORAGE_DRIVER=local-test`.

You must supply only two values locally (names below; put real values in

`.env`, never in docs or Git):

- `JWT_SECRET` — any high-entropy string of at least 32 characters

(e.g. generate one with `openssl rand -hex 32`).

- `ADMIN_BOOTSTRAP_EMAIL` / `ADMIN_BOOTSTRAP_PASSWORD` — only needed when you

run `npm run seed:admin` (section 5); not read by the HTTP server.

✗ All other blank variables (`CLOUDFLARE_*`, `R2_*`) are validated only when the matching driver is selected (`DB_DRIVER=d1` / `STORAGE_DRIVER=r2`) — see `src/config/env.validation.ts`. The validator fails fast at bootstrap and never echoes values.

2.3 Build

```
npm run build
```

2.4 Apply database migrations (local SQLite)

> **Important:** the HTTP server does **not** auto-apply migrations at

> startup. `src/main.ts` never runs them; `local.db` starts empty. You must

> apply migrations once before the first run.

```
# Applies all pending files in src/database/migrations/ to ./local.db
npx ts-node src/database/migrate.ts
```

(`npm run seed:admin` also applies pending migrations first, so seeding implicitly migrates.)

2.5 Run locally

```
npm run start:dev    # watch mode
# or
npm run start:prod   # node dist/main (after npm run build)
```

The API listens on `http://localhost:PORT/api` (default `PORT=3000`). Smoke test — the health route is `GET /api` (it returns `Hello World!` and is exempt from all throttling groups):

```
curl -i http://localhost:3000/api
curl -s http://localhost:3000/api/courses # public catalog, paginated
```

3. Environment variable reference

Names and purposes only — ****no secret values belong in this repo, in Git, in logs, or in any document.**** The three templates are `.env.example` (local, 17 names), `.env.staging.example` and `.env.production.example` (15 names each); `CORS_ALLOWED_ORIGINS` is present but blank in all three. One further name is read at runtime but is not in the example files (see the row marked ***runtime-optional***).

Variable	Purpose	Required		
<code>APP_ENV</code>	Runtime mode: <code>local</code> \	<code>staging</code> \	<code>production</code> . <code>production</code> enables HSTS in security headers.	Optional, defaults <code>local</code>
<code>PORT</code>	HTTP listen port (integer 1–65535).	Optional, defaults <code>3000</code>		
<code>DB_DRIVER</code>	Persistence driver: <code>sqlite</code> (better-sqlite3 on <code>local.db</code>) \	<code>d1</code> (Cloudflare D1 REST adapter).	Optional, defaults <code>sqlite</code>	
<code>CLOUDFLARE_ACCOUNT_ID</code>	Cloudflare account id for the D1 REST endpoint.	Required when <code>DB_DRIVER=d1</code>		

Variable	Purpose	Required	
CLOUDFLARE_D1_DATABASE_ID	D1 database id the REST adapter queries.	Required when DB_DRIVER=d1	
CLOUDFLARE_API_TOKEN	Bearer token used per-query against the D1 REST API (never stored on the service instance).	Required when DB_DRIVER=d1	
STORAGE_DRIVER	Object storage driver: local-test (in-process stub, http://local-storage.test URLs)	r2 (Cloudflare R2 via S3 presigning).	Optional, defaults local-test
R2_ENDPOINT	S3-compatible R2 endpoint (must be absolute https: URL). Its origin also feeds CSP source lists.	Required when STORAGE_DRIVER=r2	
R2_BUCKET	R2 bucket name.	Required when STORAGE_DRIVER=r2	
R2_ACCESS_KEY_ID	R2 access key id.	Required when STORAGE_DRIVER=r2	
R2_SECRET_ACCESS_KEY	R2 secret access key.	Required when STORAGE_DRIVER=r2	
JWT_SECRET	HS secret for signing/verifying access tokens (AuthGuard).	Always required (min 32 chars)	
FRONTEND_URL	Primary allowed browser origin; CORS and request-integrity fallback when CORS_ALLOWED_ORIGINS is unset.	Always required (valid http(s) URL)	
CORS_ALLOWED_ORIGINS	Comma-separated explicit whitelist of allowed origins (credentials mode; wildcards rejected). Also the request-integrity guard's allowed-origin set. Falls back to FRONTEND_URL, then http://localhost:3001.	Optional (blank in all three example files; set real origins per environment)	
CSP_CONNECT_SRC	Comma/space-separated origins added to CSP connect-src / style-src / img-src / font-src. Malformed entries are dropped. Defaults to 'self'.	Runtime-optional (not in the example files)	
TRUST_PROXY_HOPS	Express trust proxy hop count for client-IP resolution behind the edge proxy. Unset/blank → false (fail closed: X-Forwarded-For cannot mint fresh throttle buckets); non-numeric → bootstrap aborts. Staging/production templates set 1.	Optional (validated at bootstrap, not by env.validation.ts)	
ADMIN_BOOTSTRAP_EMAIL	Email of the first admin account, consumed only by npm run seed:admin.	Required for seed:admin	
ADMIN_BOOTSTRAP_PASSWORD	Password for the first admin account, consumed only by npm run seed:admin.	Required for seed:admin	

Cross-field validation lives in src/config/env.validation.ts and keys off

DB_DRIVER / STORAGE_DRIVER — not off APP_ENV.

4. Commands

Command	What it does
npm run test:esm	Unit/behavior suite (Jest with --experimental-vm-modules, via cross-env). Current baseline on this branch: 44 suites / 411 tests.
npm run test:e2e	End-to-end suite (test/jest-e2e.json harness with overridden providers). Baseline: 107 tests. Runs fully against in-memory/local SQLite — zero cloud credentials.
npm run build	nest build → dist/.
npm run lint	oxlint src/ test/.
npm run format	Prettier over src/ and test/.
npm run test:cov	Coverage report.
npm run seed:admin	Controlled first-admin bootstrap (section 5).

Command	What it does
<code>npm run docs:pdf</code>	Regenerate committed PDFs (section 6).

Plain `npm test` (`jest` without the ESM flag) is **not** usable with this

ESM-only codebase — always use `test:esm` / `test:e2e` (DL-008).

5. Adding and running a migration

Migrations are plain SQL files in `src/database/migrations/`, applied by

`src/database/migrate.ts` in **filename sort order**, tracked in the

`_migrations` table (filename + SHA-256 content hash). Rules:

1. **Add** a new file `NNNN_short_description.sql` continuing the numeric prefix (next free number after `0007_...`). Name only — content of applied files is immutable.
2. **Never edit an applied migration.** The runner compares the recorded hash and throws on drift (`"changed after it was applied"`), fail-closed. Fix forward with a new file.
3. Statements are split with a string/comment/trigger-aware splitter, so plain `;`-separated DDL is safe.
4. **Run locally:** `npx ts-node src/database/migrate.ts` (applies to `./local.db` under the current working directory; prints `applied/skipped` counts). The HTTP server itself never runs it.
5. **Run against D1 (staging/production):**
`npx wrangler d1 migrations apply xolvon-staging --remote` — the database name and `migrations_dir` are configured in `wrangler.jsonc`. See `deployment-runbook.md` for the full procedure and rollback policy (forward-only; compensating migration + deployment revert).
6. The `src/database/migrations/_reference/` folder is a reference copy and is **not** applied (the runner only enumerates top-level `*.sql` files).
7. Schema changes must be preceded by a `decision-log.md` entry (RULES §84); `SCHEMA.md` remains the schema source of truth.

6. Generating documentation PDFs

Per DL-019, official PDFs are produced with Playwright/Chromium and committed:

```
npm run docs:pdf
```

- Runs `scripts/docs-pdf.mjs`: renders the **four official handover docs** (`README.md`, `architecture.md`, `security.md`, `deployment-runbook.md`) to `docs/pdf/<name>.pdf` (A4, Chromium print pipeline), plus a combined `docs/pdf/xolvon-backend-full-documentation.pdf` in that order. It does **not** render the other `docs/*.md` (`api-contract`, `decision-log`, `qa-results`, `production-operations`) — the deliverable set is pinned in the script.
- Requires the Chromium browser binary once per machine:
`npx playwright install chromium`.

- Output is deterministic for the same Markdown input; regenerate and

secret scan whenever these docs change.

- `docs/Xolvon-API-Documentation.pdf` (and its generator `scripts/generate-api-pdf.py`) were a non-conforming, out-of-band pair (per DL-019) and were **deleted at plan T9**; they are not part of this workflow and no longer exist in the tree. See DL-026 in `decision-log.md`.

7. House rules for contributors

- No secret or credential values in docs, tests, logs, Postman files, PDFs, or

Git history — variable **names** only (DL-024, cleanup policy DL-025).

- No production deployment claims without real target + HTTPS domain +

verification evidence (current status: blocked, see

`qa-results.md`).

- Endpoint or auth-model changes require updating

`api-contract.md` and a `decision-log.md` entry in the same change.